

VPN Security

A Comprehensive Technical Guide

Architecture · Protocols · Cryptography
Threats · Hardening · Modern Alternatives

With Clear Diagrams and Tables

Swastik Sagar

Technical Reference

August 26, 2026

Contents

1	Introduction to VPN Security	1
1.0.1	Core Security Goals	1
2	How VPNs Work	2
2.0.1	Tunneling Explained	2
2.0.2	Key Exchange Process	2
3	VPN Architectures	3
4	VPN Protocols	4
4.1	WireGuard	4
4.2	OpenVPN	4
4.3	IKEv2 with IPsec	4
4.4	Protocols That Should Be Avoided	4
5	Cryptography Used in VPNs	5
6	Authentication Methods	6
7	Threat Landscape	7
8	Hardening Best Practices	8
9	VPN versus Zero Trust	9
10	Conclusions and Recommendations	10
A	Glossary	11

Chapter 1

Introduction to VPN Security

A Virtual Private Network (VPN) is a technology that creates a secure, encrypted connection over a less secure network, such as the public Internet. The main purpose of a VPN is to protect data while it travels between the user and the destination server.

When you use the Internet without a VPN, your data can be seen by your Internet Service Provider, network administrators, or attackers on the same network. A VPN solves this problem by creating an encrypted tunnel. All your data passes through this tunnel, so outsiders can only see encrypted information.

1.0.1 Core Security Goals

The four fundamental security goals of a VPN are:

- **Confidentiality:** Only authorized parties can read the data. Encryption makes the content unreadable to anyone who intercepts it.
- **Integrity:** The data cannot be changed without detection. If an attacker modifies a packet, the receiver will know.
- **Authentication:** Both sides of the connection prove their identity. This prevents connecting to a fake server.
- **Anti-replay protection:** Old packets that were captured earlier cannot be sent again by an attacker.

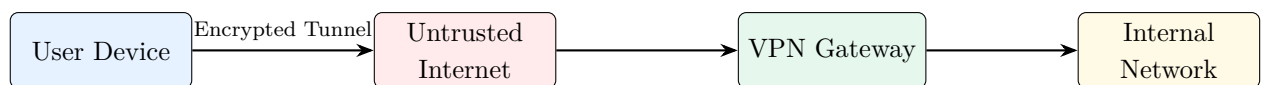


Figure 1.1: Basic concept of a VPN tunnel

Chapter 2

How VPNs Work

2.0.1 Tunneling Explained

Tunneling is the process of taking an original network packet, encrypting it, and placing it inside a new packet. The new outer packet is used only for routing across the Internet. When this packet reaches the VPN gateway, the outer header is removed, the content is decrypted, and the original packet is delivered to its real destination.

This process hides both the content of your communication and, in many cases, the final destination from intermediate observers.

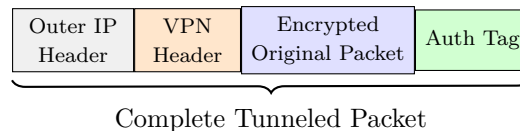


Figure 2.1: Structure of a tunneled VPN packet

2.0.2 Key Exchange Process

Modern VPNs use a two-step cryptographic process:

1. **Asymmetric Key Exchange:** Algorithms such as X25519 or Elliptic Curve Diffie-Hellman are used at the beginning of the connection to safely create a shared secret between the client and the server.
2. **Symmetric Encryption:** After the shared secret is established, fast symmetric algorithms (AES-256-GCM or ChaCha20-Poly1305) are used to encrypt all actual data. These algorithms also provide integrity protection (AEAD).

Perfect Forward Secrecy (PFS) is an important property. It means that even if an attacker later steals the server's long-term private key, they still cannot decrypt past sessions.

Chapter 3

VPN Architectures

There are three main ways to deploy a VPN. Each architecture serves a different purpose.

- **Remote Access VPN:** This is the most common type for individual users. A person connects from a laptop or mobile phone to the company network so they can work securely from home or while traveling.
- **Site-to-Site VPN:** Two or more fixed networks (for example, the headquarters and a branch office) are permanently connected through an encrypted tunnel. Users inside those networks do not need to run VPN software themselves.
- **Mesh VPN:** Every device can connect directly to other devices. This model is becoming popular with modern tools based on WireGuard.

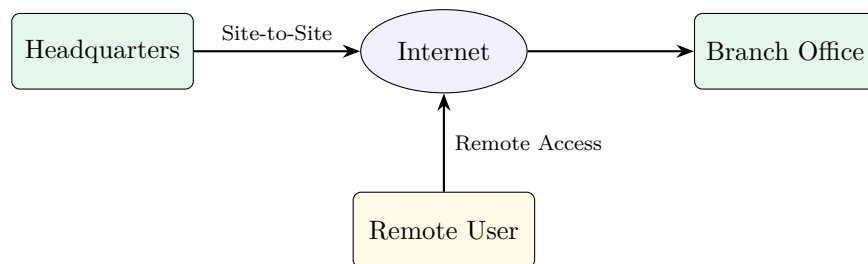


Figure 3.1: Common VPN deployment models

Chapter 4

VPN Protocols

The protocol is the set of rules that the client and server use to create and maintain the encrypted tunnel. The choice of protocol has a large impact on speed, security, and compatibility.

4.1 WireGuard

WireGuard is the modern recommended protocol for most users. It uses a small and carefully chosen set of strong cryptographic algorithms. Because its codebase is very small (about 4,000 lines), it is easier to audit and less likely to contain hidden vulnerabilities. It also offers excellent performance and low battery consumption.

4.2 OpenVPN

OpenVPN is a mature and highly flexible protocol that has been audited many times over the years. It can run over both UDP and TCP. When it runs over TCP port 443, it becomes useful for bypassing restrictive firewalls. It supports strong modern ciphers such as AES-256-GCM and ChaCha20-Poly1305.

4.3 IKEv2 with IPsec

IKEv2 combined with IPsec is especially suitable for mobile devices. The MOBIKE feature allows the connection to survive network changes, for example when a phone moves from Wi-Fi to mobile data.

4.4 Protocols That Should Be Avoided

PPTP is cryptographically broken and must never be used. L2TP/IPsec can be acceptable only when configured with strong modern algorithms, but it is frequently configured weakly in practice.

Table 4.1: Comparison of Major VPN Protocols

Protocol	Speed	Security	Auditability	Recommendation
WireGuard	Excellent	Excellent	Excellent	Preferred
OpenVPN	Good	Excellent	Very Good	Strong alternative
IKEv2/IPsec	Very Good	Good–Excellent	Good	Good for mobile
L2TP/IPsec	Moderate	Moderate	Limited	Legacy only
PPTP	Fast	Poor	Poor	Never use

Chapter 5

Cryptography Used in VPNs

Cryptography is the foundation of VPN security. Using weak algorithms can make the entire VPN useless, even if everything else is configured correctly.

Table 5.1: Recommended Cryptographic Algorithms

Purpose	Recommended Choice
Key Exchange	X25519 or strong Elliptic Curve Diffie-Hellman
Encryption + Integrity	AES-256-GCM or ChaCha20-Poly1305
Hashing	SHA-384, SHA-512 or BLAKE2s

Algorithms that should be avoided include MD5, SHA-1, 3DES, DES, and any use of CBC mode without proper integrity protection.

Chapter 6

Authentication Methods

Encryption protects the data, but authentication answers the question: “Am I really talking to the correct server, and is the user really who they claim to be?”

Common authentication methods include:

- **Digital Certificates (X.509):** The preferred method in enterprise environments. Certificates provide strong cryptographic proof of identity.
- **Certificate + Multi-Factor Authentication:** Currently one of the strongest practical combinations.
- **Username and Password + Multi-Factor Authentication:** Widely used for remote access. The multi-factor part is essential.
- **Pre-shared Keys:** Simple to set up but only suitable for small and tightly controlled environments.

Chapter 7

Threat Landscape

Even when strong encryption is used, a VPN can still fail if other parts of the system are weak. The most important real-world threats are:

1. DNS leaks and WebRTC leaks that reveal the websites you visit
2. Failure of the kill switch, which can expose traffic when the VPN disconnects
3. Routing attacks such as TunnelVision (DHCP Option 121)
4. Manipulation of the operating system routing table
5. Session manipulation attacks
6. Bugs in the VPN client or server software
7. A malicious or heavily logging VPN provider
8. Future quantum computers that may break today's key exchange algorithms

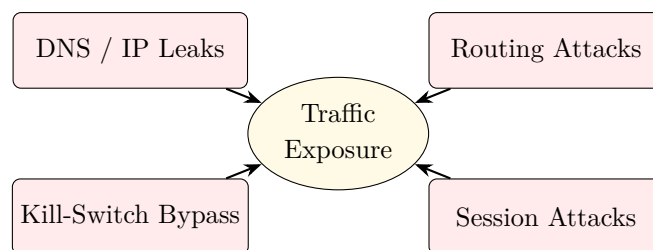


Figure 7.1: Main paths that can lead to traffic exposure

Chapter 8

Hardening Best Practices

To make a VPN as secure as possible, the following practices should be followed:

1. Prefer WireGuard or a carefully configured OpenVPN / IKEv2 setup
2. Allow only modern AEAD ciphers
3. Always require Perfect Forward Secrecy
4. Use strong authentication (certificates + multi-factor authentication when possible)
5. Implement a reliable network-level kill switch
6. Force all DNS queries to travel inside the VPN tunnel
7. Handle IPv6 correctly (either disable it or tunnel it completely)
8. Keep both client and server software up to date
9. Minimize logging and prefer independently audited providers
10. Apply the principle of least privilege

Chapter 9

VPN versus Zero Trust

Traditional VPNs usually give a user relatively broad access to the network after successful authentication. Zero Trust Network Access (ZTNA) follows a different philosophy: never trust, always verify. Each request is checked, and users receive access only to the specific applications they need.

Table 9.1: Traditional VPN vs Zero Trust Network Access

Aspect	Traditional VPN	Zero Trust / ZTNA
Trust Model	Authenticate once	Continuous verification
Access Scope	Network segment	Specific applications only
Lateral Movement	Relatively easy	Strongly limited
Cloud Fit	Often requires hairpinning	Native direct access
Attack Surface	Public VPN gateway	Minimal exposure

Chapter 10

Conclusions and Recommendations

- **For personal use:** Choose a WireGuard-based VPN from a reputable provider that has been independently audited.
- **For high-security environments:** Use OpenVPN or IKEv2 with strict cipher suites and certificate-based authentication.
- **For enterprises:** Prefer Zero Trust Network Access for user remote access, and keep hardened WireGuard or IPsec for site-to-site connections.

A correctly designed and operated VPN is a powerful security control. However, it should always be treated as one part of a larger security architecture rather than a complete solution by itself.

Appendix A

Glossary

AEAD	Authenticated Encryption with Associated Data
PFS	Perfect Forward Secrecy
ZTNA	Zero Trust Network Access

Written by Swastik Sagar

Technical reference based on public standards and best practices.